Security Evidence Toolkit · Handbook

Why every question is asked, which source stands behind it, and what a small business can honestly show

Sources read at the originals on 19 October 2026

0 How to use this toolkit

The toolkit turns forty answers into seven dated documents. This handbook explains why each question is asked, which source stands behind it, which answer a questionnaire, an insurer or a contract clause actually wants, and what a business without an IT department can honestly show. You do not need to read it before you start. Every question in the generator names the section that explains it.

The seven documents. D1 the security self-declaration: nine sections A to I, one overview table, every field with its status and date, signed by the management; it is the document you attach to a questionnaire. D2 the action plan: every "partly" and "not yet" becomes a measure with a priority, a responsible person, a target date in one of three waves and the evidence that exists afterwards; as a sheet with a review tab. D3 the emergency card: one page for the wall and the drawer. D4 the evidence list: per question the proof a customer or insurer accepts, whether it exists, where it is, its attachment number. D5 the cover letter with the questionnaire mapping: the letter that names the gaps with their dates, and the table that maps the typical questions of a questionnaire and the ten areas of Article 21(2) of the NIS 2 Directive to the sections of the self-declaration. D6 the clause checklist: the security clauses customers write into contracts, what each means, what a small business can promise and what it should negotiate. D7 the evidence summary: one dated page with a document number.

The four answers. Every status question has four answers: in place, partly, not yet with a date, not applicable with a reason. "Not yet, by the end of the quarter" is a complete answer. A questionnaire that gets it learns more than from a "yes" that falls apart at the first follow-up question, and the law that covers your customer expects exactly this of the customer itself: whoever finds a gap takes corrective measures without undue delay (section 1.7). The toolkit never writes "all requirements met", "secure", or a deadline you cannot keep.

What the toolkit is not. It is not legal advice, not an audit and not a certificate. No document claims that the business complies with a law or a standard. The documents show what the business has in place on a given date, what it will do by when, and who answers for it. Where a source is missing, the handbook says so and leaves the decision with the business.

The four markers. Every statement that matters carries one of four markers. Fact: wording or date read at the original source, which is named with its retrieval date. Interpretation: a conclusion Scutoria draws from the sources; it can be argued with. Uncertain: the sources contradict each other or the legal situation is open; the handbook says what was checked and when. Gap: no source answers the question; the business decides and the document leaves the field open on purpose.

The example business. The generator is prefilled with a fictional electrical contractor with ten to forty-nine staff in Austria, whose IT is looked after partly by an external provider and partly by the office. A customer has sent a questionnaire. The example answers show a realistic mixed picture: multi-factor authentication on email yes, on the cloud console not yet; a daily backup, but no copy out of reach; a restore never tested; no emergency plan; an old workshop computer. No person and no business in this handbook is real.

The order of work. Answer the questions; about forty minutes. Read D1 and the action plan. Print the emergency card and check its numbers. Create the evidence that already exists in an hour (section 3). Send the self-declaration with the cover letter, or file it for the insurer. Work through the first wave of the plan. Review on the date in D7.

1 Why you are asked

Four kinds of requests arrive at small businesses: a questionnaire from a larger customer, a contract with security clauses, an application form of a cyber insurer, and the wish to show a label or a certificate. This section says where each comes from and why the size of the business sets the measure.

1.1 Customers under the NIS 2 Directive

FACT

The NIS 2 Directive applies to public or private entities of a type listed in its Annex I or II which qualify as medium-sized enterprises under the Commission's SME Recommendation or exceed those ceilings, with exceptions regardless of size in Article 2(2). Medium-sized means fifty persons or more, or a turnover and a balance sheet total both above ten million euro, up to 249 persons and fifty or forty-three million euro. The sectors include energy, transport, banking, health, water, digital infrastructure, public administration, space, postal services, waste, chemicals, food, the manufacturing of medical devices, computers, electrical equipment, machinery and vehicles, digital providers and research.

→ Source: Directive (EU) 2022/2555, Art. 2(1) and (2), Annexes I and II · EUR-Lex · retrieved 2026-10-19; Commission Recommendation 2003/361/EC, Annex, Art. 2 · retrieved 2026-10-19

FACT

Such entities must take "appropriate and proportionate technical, operational and organisational measures". The measures must include at least ten areas, among them "supply chain security, including security-related aspects concerning the relationships between each entity and its direct suppliers or service providers". When deciding which supply chain measures are appropriate, entities "take into account the vulnerabilities specific to each direct supplier and service provider and the overall quality of products and cybersecurity practices of their suppliers and service providers, including their secure development procedures".

→ Source: Directive (EU) 2022/2555, Art. 21(1), (2)(d) and (3) · EUR-Lex · retrieved 2026-10-19

INTERPRETATION

This is the questionnaire. The Directive does not tell the customer what to ask a supplier; it obliges the customer to consider the supplier's practices, and a questionnaire is the cheapest way to do that for hundreds of suppliers at once. The questions therefore follow the customer's own ten areas, and the self-declaration follows the questions. The Directive binds the customer, not you; what binds you is the contract that follows (section 1.2 and D6).

FACT

The Directive is transposed by national law. In Germany the amended BSI Act has been in force since 6 December 2025. In Austria the Network and Information System Security Act 2026 (NISG 2026) has been in force in its core provisions since 1 October 2026; its § 32(4) repeats the ten areas, with supply chain security including the relationships with direct suppliers and service providers in point (d), and its § 33(1) requires essential and important entities to send the authority a structured self-declaration within twelve months of the registration duty arising, in particular on the network and information systems used and the security of the supply chains.

→ Source: BSI-Gesetz as amended by the German NIS 2 transposition act, in force since 6 December 2025 · gesetze-im-internet.de · retrieved 2026-10-19; NISG 2026, BGBl. I No. 94/2025 of 23 December 2025, § 32(4), § 33(1) · ris.bka.gv.at · retrieved 2026-10-19

INTERPRETATION

For an Austrian customer, the supplier questionnaire is the raw material of its own self-declaration. Whoever asks you in 2026 is collecting what it has to send to the authority in 2027. That explains the tone and the deadlines of the requests; it does not make your answers a filing with the authority. The self-declaration describes your business; the customer decides what it does with it.

1.2 The Implementing Regulation: the contract behind the questionnaire

FACT

For digital providers (DNS, cloud, data centres, managed services, online marketplaces, search engines, social networks, trust services) the Commission has laid down the technical requirements of the ten areas in Implementing Regulation (EU) 2024/2690, published in the Official Journal on 18 October 2024 and in force since 7 November 2024. Its Annex, point 5.1.4, says what such entities put into their contracts with suppliers "where appropriate": cybersecurity requirements; awareness, skills, training and, where appropriate, certifications required of the supplier's staff; background checks of the supplier's staff; an obligation to report incidents "without undue delay"; the right to audit or to receive audit reports; an obligation to handle vulnerabilities; requirements regarding subcontracting; and obligations upon termination of the contract, such as "retrieval and disposal" of the information obtained. Point 5.2 requires a directory of direct suppliers with contact points and a list of the products and services each supplies.

→ Source: Commission Implementing Regulation (EU) 2024/2690 of 17 October 2024, OJ L, 2024/2690, 18.10.2024, Art. 2(1), Art. 16, Annex points 5.1.4 and 5.2 · EUR-Lex, English and German · retrieved 2026-10-19

FACT

In Austria the same Annex applies to every essential and important entity: the regulation of the cybersecurity authority of 1 October 2026 (NISV 2026) declares the requirements of Article 2 and the Annex of the Implementing Regulation applicable to the types of entities listed in Annexes 1 and 2 of the NISG 2026 that the Implementing Regulation itself does not cover.

→ Source: NISV 2026, BGBl. II No. 290/2026 of 1 October 2026, § 2 · ris.bka.gv.at · retrieved 2026-10-19

INTERPRETATION

So the eight contract contents of point 5.1.4 are the pattern of the clauses you will see: from digital providers across the Union, and from every NIS 2 customer in Austria. A German customer outside the digital sectors is not bound to the Annex by law, but its auditors and lawyers read the same text. D6 takes the eight contents one by one and says what a small business can promise.

1.3 Financial customers: DORA

FACT

Banks, insurers, investment firms and other financial entities fall under the Digital Operational Resilience Act. Its Article 30(2) lists nine contents that every contract on ICT services must contain, among them a description of the service including subcontracting, the locations of data processing and prior notice of their change, data protection provisions, access and return of data, service levels, assistance in incidents, cooperation with authorities and termination rights. Article 30(3) adds six for critical or important functions, among them full service levels, notice periods and reporting duties, contingency plans and security measures, participation in threat-led penetration testing, unrestricted access and audit rights, and exit strategies.

→ Source: Regulation (EU) 2022/2554 (DORA), Art. 28(8), Art. 30(2) and (3) · EUR-Lex · retrieved 2026-10-19

INTERPRETATION

A small supplier of an insurer or a bank meets these as a finished clause set it is asked to sign. Part B of D6 explains each; the honest answer to most is "yes, within these limits", and the audit right is the one to negotiate: unrestricted access is written for cloud providers, not for an electrician with one server.

1.4 Insurers

FACT

Six public application forms and conditions of cyber insurers were read in full. What all of them ask: daily backups on separate systems with a tested restore (Mannheimer 4.1, 4.2, 4.5, 4.6, 4.9; Markel section 4 point 5 and 7.2; Beazley critical requirement 1; Funk 1); multi-factor authentication for cloud services, email, remote access and administrators (Mannheimer 7.7.1, 7.7.3, 8.1; Markel 6.2; Allianz 2.5.5; Beazley 2 and 3); patches applied promptly and no software without manufacturer updates (Mannheimer 7.1; Markel 7.3, within four weeks, CVSS 8.0 or higher without delay; Allianz 2.5.1 and 2.5.3; Beazley and Funk 5); protective software on all devices with automatic updates (Mannheimer 7.2; Markel 7.3; Beazley; Funk 7); annual training with anti-phishing (Mannheimer 5.4; Markel 6.4; Beazley 4; Funk 4); a responsible person and a written emergency and recovery plan (Mannheimer 5.1, 5.10; Markel 6.3); administrator rights only for administration (Mannheimer 6.3, 6.5; Allianz 2.5.4); a process for granting and revoking access (Mannheimer 5.5); network segmentation (Mannheimer 7.4). Beazley calls four of these a mandatory condition for taking out cyber cover. The conditions of an Austrian insurer oblige the policyholder to use appropriate protective measures, in particular for backups, anti-virus software, password settings, authorisation concepts, system configuration, firewalls and software updates, to notify the insurer at the latest within one week of becoming aware, and cover private devices only where their access is subject to two-factor authentication.

→ Source: Mannheimer Versicherung AG, Fragebogen Cyber-Risiken, HF_060 0424; Markel Insurance SE, Fragebogen Pro Cyber v2; Allianz Versicherungs-AG, Fragebogen für Unternehmen der Informationstechnologie, 9.25; Beazley, Sicherheitsanforderungen für die Cyber Versicherung; Funk International Austria with Beazley, Antrag und Risikofragebogen, July 2022; Donau Versicherung AG, Allgemeine Bedingungen für die Cyberversicherung, Fassung 2025, Teil D 7.1.3 and 7.1.4, Teil E · retrieved 2026-10-19

◆ INTERPRETATION

The insurers ask the same seven things the law makes customers ask, in plainer words and with numbers. Where the toolkit names a rhythm (daily, yearly, within days), it takes the strictest of the forms, because the self-declaration must hold in front of all of them. Where a form is stricter than the law, the handbook says so at the question.

1.5 Labels, checks and certificates

■ FACT

Austria has a label with four levels. The Cyber Trust Austria label is issued by CTS Cyber Trust Services GmbH; the underlying rating belongs to KSV1870 and the scheme to the Kompetenzzentrum Sicheres Österreich. The Standard level rests on a self-declaration against fourteen published questions (B1 to B14), validated by KSV1870; Silver and Gold add eleven questions (A1 to A11), Gold with an audit by a qualified body; Platinum rests on the fifty requirements of the Implementing Regulation. The label is valid for one year. Its scheme policy, version 6.0 of 8 September 2025, publishes the questions; the website names suppliers of essential and important entities under the NISG 2026 as its target.

→ Source: Cyber Trust Austria, Cyber Risk Rating & Cyber Trust Label Schema Policy 2026, version 6.0 of 8 September 2025, pp. 5 to 21; cyber-trust.at, label overview and B questions · retrieved 2026-10-19

■ FACT

Germany has a check, not a certificate. The CyberRisikoCheck under DIN SPEC 27076:2023-05 is a one- to two-hour interview by a qualified IT service provider against 27 requirements in six areas, aimed at businesses with up to fifty staff; the BSI says it is not an IT security certification and does not establish NIS 2 conformity; the DIN SPEC is free after registration. The BSI qualified its thousandth provider on 6 June 2025 and reports that businesses met on average only just under 56 percent of the requirements. VdS 10000:2025-01 is a management standard for SMEs by the insurers' testing body, based on ISO 27001 and the BSI baseline, with certification valid for three years and reduced annual re-audits; insurer forms name it next to ISO 27001.

→ Source: BSI, CyberRisikoCheck page and press release of 6 June 2025; BSI, Die Lage der IT-Sicherheit in Deutschland, section on SMEs; DIN Media, DIN SPEC 27076; VdS 10000 : 2025-01 (03), table of contents and preliminary remarks; VdS 5569 : 2018-10, pp. 5 and 9 · retrieved 2026-10-19

FACT

ISO/IEC 27001:2022 is the international standard; its Annex A lists 93 controls in four themes, taken from ISO/IEC 27002:2022. The standard is paid (CHF 155). TISAX is the assessment scheme of the automotive industry on the VDA ISA catalogue, operated by ENX, with three assessment levels and three-year validity. The SIG of Shared Assessments is a questionnaire library sold by subscription with 21 risk domains.

→ Source: committee.iso.org and IEC Webstore, ISO/IEC 27001:2022, edition 3; SC 27 Journal 2025, issue 1, pp. 10, 18 to 19; ENX Association, TISAX handbook and NIS2 fulfilment through TISAX, 24 April 2025; Shared Assessments, SIG · retrieved 2026-10-19

INTERPRETATION

For a business with ten to fifty staff, none of these is the first step, and most customers do not demand one. We searched for a customer or a tender that requires the Austrian label and found none; only press releases of label holders. The order that works: first the self-declaration with evidence (this toolkit), then, if a customer or insurer asks for an external check, the cheapest matching one: the CyberRisikoCheck in Germany, the Standard label in Austria, both of which ask the questions of blocks B to H in their own words. Question B3 records what you already have; D4 lists a certificate as an attachment, nothing more.

1.6 Why size sets the measure

FACT

The Directive itself ties the measures to size: "due account shall be taken of the degree of the entity's exposure to risks, the entity's size and the likelihood of occurrence of incidents and their severity". The Implementing Regulation repeats this for its Annex and adds that an entity which considers a requirement not appropriate, applicable or feasible documents its reasons; its recital 5 says micro entities that cannot segregate duties may rely on compensating measures such as targeted oversight by management or increased monitoring. Austrian law repeats the test in § 32(3) NISG 2026, and its regulation obliges entities to document compensating measures and review them yearly.

→ Source: Directive (EU) 2022/2555, Art. 21(1) second subparagraph; Implementing Regulation (EU) 2024/2690, Art. 2(2) and recital 5; NISG 2026, § 32(3); NISV 2026, § 4 · retrieved 2026-10-19

◆ INTERPRETATION

Proportionality is written for the entity, not for its suppliers, but a customer that must document why a measure is appropriate for itself cannot demand more of a ten-person supplier than of itself. That is why the self-declaration opens with the size of the business (question A3) and why D5 says in its first paragraph that the answers are those of a small business. Nothing in the toolkit asks a small business for a security operations centre, penetration tests or a certification; those are the Silver and Gold questions of the label, not the Standard ones.

1.7 Why "not yet, with a date" is a complete answer

■ FACT

The Directive obliges an entity that finds it does not comply with the measures to take "without undue delay, all necessary, appropriate and proportionate corrective measures". The Implementing Regulation asks for compliance monitoring and regular reporting to the management bodies; Austria's § 33(3) expects an audit report with the identified deficiencies and an action plan to remedy them.

→ Source: Directive (EU) 2022/2555, Art. 21(4); Implementing Regulation (EU) 2024/2690, Annex 2.2.1; NISG 2026, § 33(3) · retrieved 2026-10-19

◆ INTERPRETATION

The law knows the gap with a plan as the normal state; it punishes the hidden gap, not the documented one. A supplier that writes "not yet, planned by 31 March, responsible: the office manager with the IT provider" gives the customer what the customer must produce for itself. That is the whole reasoning behind the four answers and the action plan, and it is why D7 lists open points instead of hiding them.

2 The areas of the self-declaration

Each area is one block of the questionnaire and one section of D1. For each question the handbook says what is asked, which source asks it, what a small business can realistically show, and what the example business answered. The emergency questions of block F are explained in section 4 as well. Quotations from German sources are our translations.

2.1 B · Organisation

B1 Written security rules. One or two pages for staff: devices, passwords, email, payments, what to report and to whom.

FACT

The first question of the Austrian label is whether the business has a current information security policy that is valid for the company. The first of ENISA's twelve steps for SMEs is to develop a security culture, with "publish cybersecurity policies" among its sub-steps. The Implementing Regulation opens its Annex with the policy on the security of network and information systems; VdS 10000 devotes chapters 5 and 6 to the policy and the guidelines; Mannheimer asks for a responsible person.

→ Source: Cyber Trust Austria, Schema Policy 2026, B1; ENISA, Cybersecurity guide for SMEs, 12 steps, 28 June 2021, step 1; Implementing Regulation (EU) 2024/2690, Annex 1.1; VdS 10000:2025-01, chapters 5 and 6; Mannheimer, 5.1 · retrieved 2026-10-19

INTERPRETATION

Two pages signed by the management and acknowledged by each person are enough for every questionnaire we read; nobody asks a ten-person business for a management system. The example business has rules for passwords and email but not for payments and reporting: "partly", with the rules completed in the first wave.

B2 Cyber insurance. Whether a policy exists, with insurer, emergency number and notification deadline.

INTERPRETATION

No law requires a cyber insurance, and no questionnaire we read asks for it as a condition; the question stands because insurers' own forms, the label's question A9 (qualified resources in a serious incident, possibly through a cyber insurance) and the emergency card need the answer: the policy's emergency number and its notification deadline belong on the card. D1 reports the fact without judgement. The example business has no policy.

→ Source: Cyber Trust Austria, Schema Policy 2026, A9; Donau Versicherung, AVB Cyber 2025, Teil D 7.1.4 · retrieved 2026-10-19

B3 Certificates, labels, checks. What the business already holds: ISO 27001, the Austrian label, TISAX, a CyberRisikoCheck, other.

FACT

Insurers ask for it: Allianz 1.2 lists ISO 27001 and VdS 10000; Mannheimer 5.3 asks whether the business runs regular analyses against ISO 27001, the BSI baseline or DIN SPEC 27076, and 9.2 whether the IT provider is certified. The Implementing Regulation asks relevant entities for an independent review of their security and for policies to assess effectiveness.

→ Source: Allianz, 1.2; Mannheimer, 5.3 and 9.2; Implementing Regulation (EU) 2024/2690, Annex 2.3 and 7 · retrieved 2026-10-19

INTERPRETATION

What exists becomes an attachment in D4; what does not exist is not a gap in the plan, because section 1.5 explains why a certificate is not the first step. The example business holds none.

2.2 C · Access and identity

C1 One account per person.

FACT

Markel's form asks whether an individual user ID with password is assigned to every user and administrator. The Implementing Regulation requires identification of users and authentication; the BSI baseline module on identity and access management asks for individual accounts; TISAX control 4.1.3 asks how user accounts and login information are managed.

→ Source: Markel, 6.2; Implementing Regulation (EU) 2024/2690, Annex 11.5 and 11.6; BSI, IT-Grundschutz ORP.4, edition 2023; ENX, NIS2 fulfilment through TISAX, control 4.1.3 · retrieved 2026-10-19

INTERPRETATION

Shared logins break every other control: you cannot revoke, log or attribute. Where a tool allows only one login, the measure in D2 keeps its password in the password manager with a named owner. The example business answered "in place".

C2 Multi-factor authentication for every email account.

FACT

The insurers put it first: Beazley's critical requirement 2 and Funk's question 2 ask for multi-factor authentication for cloud-based services, with cloud-based email accounts as the example, and for all remote access. The Austrian label's B6 asks for appropriate authentication with the criterion that MFA must be in use at least for critical systems. The Implementing Regulation requires that users are authenticated "by multiple authentication factors or continuous authentication mechanisms", where appropriate and in accordance with the classification of the asset; the Directive names multi-factor authentication in Article 21(2)(j). ENISA's step 5 is "secure access to systems" with "enable multi-factor authentication"; the Austrian criminal police office lists MFA for email accounts first among the technical measures against CEO fraud.

→ Source: Beazley, requirement 2; Funk, question 2; Cyber Trust Austria, Schema Policy 2026, B6; Implementing Regulation (EU) 2024/2690, Annex 11.7.1; Directive (EU) 2022/2555, Art. 21(2)(j); ENISA, 12 steps, step 5; Bundeskriminalamt, CEO Fraud, updated 29 June 2026 · retrieved 2026-10-19

FACT

On the method: the US standard for digital identity treats phishing resistance as a property of the authenticator, and CISA ranks authenticator apps and security keys above codes by SMS, which it places last among MFA methods but still above a password alone.

→ Source: NIST SP 800-63B-4, July 2025; CISA, Implementing Phishing-Resistant MFA, October 2022 · retrieved 2026-10-19

◆ INTERPRETATION

That every mailbox is "critical" is our conclusion, not the label's wording: ENISA's SME report describes the compromised mailbox as the start of payment fraud, and the first thing an attacker does with a mailbox is reset the passwords of everything else. The example business has an authenticator app on every mailbox: "in place".

C3 Multi-factor authentication for remote access, administrators, cloud consoles and online banking.

■ FACT

Mannheimer asks whether MFA is used for access to important systems, whether administrators necessarily need MFA for the internal servers and cloud structures, and whether home office access is possible only with MFA. Markel asks for MFA for remote access to all systems and for administrator access and, for larger businesses, allows remote access only with two-factor authentication or VPN. Allianz asks whether logins from outside the company network are possible only with MFA. Beazley's requirements 2 and 3: MFA for all remote access, no remote access without VPN. The label's A6 names MFA for all externally reachable systems such as VPN, jump hosts, remote support tools and webmail. The Implementing Regulation requires strong identification, authentication such as multi-factor authentication and authorisation procedures for privileged accounts and system administration accounts, and controls for remote access including access by service providers. The Austrian insurer covers private devices only where their access is subject to two-factor authentication.

→ Source: Mannheimer, 7.7.1, 7.7.3, 8.1; Markel, section 4 point 6 and 6.2; Allianz, 2.5.5; Beazley, 2 and 3; Cyber Trust Austria, Schema Policy 2026, A6; Implementing Regulation (EU) 2024/2690, Annex 11.3.2(a) and 6.7.2(d); Donau Versicherung, AVB Cyber 2025, Teil E · retrieved 2026-10-19

◆ INTERPRETATION

Online banking is on the list because the bank already enforces a second factor and because the emergency card names the bank; no questionnaire asks for it. The example business: VPN yes, the administration console of the cloud not yet: "partly", first wave.

C4 Accounts of leavers disabled on the day of leaving, from a list of all accounts.

■ FACT

Mannheimer asks whether a formal process for the assignment and revocation of access rights exists. The Implementing Regulation requires procedures for the termination or change of employment, the management of access rights and the return or deletion of assets upon termination; the label's B4 asks for a maintained directory of all IT assets and services including cloud services; ENISA's SME report lists revoking access when staff leave among its recommendations.

→ Source: Mannheimer, 5.5; Implementing Regulation (EU) 2024/2690, Annex 10.3, 11.2, 12.5; Cyber Trust Austria, Schema Policy 2026, B4; ENISA, Cybersecurity for SMEs, June 2021 · retrieved 2026-10-19

◆ INTERPRETATION

"On the day of leaving" is our rule; the sources say "procedure". The list of all accounts per person is the evidence that makes the procedure possible, and it is the same list C1 needs. The example business has no written list: "partly".

C5 Daily work without administrator rights, separate accounts for administration.

■ FACT

Mannheimer asks whether administrative access is reserved exclusively to administrators and exclusively for administrative tasks, and whether local administrator rights on clients were disabled; Allianz asks for differentiated admin rights; the label's B5 asks for an authorisation concept that grants only the rights necessary for the work. The Implementing Regulation requires dedicated accounts to be used exclusively for system administration operations and separate credentials for privileged or administrative accounts.

→ Source: Mannheimer, 6.3 and 6.5; Allianz, 2.5.4; Cyber Trust Austria, Schema Policy 2026, B5; Implementing Regulation (EU) 2024/2690, Annex 11.3.2(b) and 11.6.2(f) · retrieved 2026-10-19

◆ INTERPRETATION

This is the one measure that costs nothing and stops most malware from installing. The example business works with administrator rights on every machine: "not yet", first wave, with the IT provider.

C6 Password rule: one long password per account in a password manager, changed only on suspicion.

■ FACT

The US standard requires at least fifteen characters where the password is the only factor and eight where a second factor is used, forbids composition rules and periodic change unless there is evidence of compromise, requires a check against blocklists of known passwords, and permits password managers. The BSI argued publicly against forced periodic changes on 31 January 2025 and 30 January 2026. The Austrian insurer's conditions name password settings among the obligations of the policyholder.

→ Source: NIST SP 800-63B-4, July 2025, sections 3.1.1.1 and 3.1.1.2; BSI press releases of 31 January 2025 and 30 January 2026; Donau Versicherung, AVB Cyber 2025, Teil D 7.1.3 · retrieved 2026-10-19

◐ UNCERTAIN

The Implementing Regulation points the other way: it requires relevant entities to demand the change of authentication data at first use, at predefined intervals and whenever there is a suspicion that the data has been compromised, to block users after a predefined number of failed attempts, and to match the strength of authentication to the asset.

→ Source: Implementing Regulation (EU) 2024/2690, Annex 11.6.2(a), (c) and (d), English and German text · retrieved 2026-10-19

◐ UNCERTAIN **Which password rule should a supplier promise?**

The standards bodies and the Commission's Implementing Regulation differ on periodic change. The toolkit follows NIST and the BSI: long, unique, in a manager, changed on suspicion, protected by a second factor. If a customer or an insurer insists on intervals and cites the Regulation, the honest answer is to agree an interval for accounts that have no second factor and to keep MFA everywhere else; D1 states which rule applies. No court or authority decision on this conflict was searched.

LAST CHECKED 2026-10-19 · OPEN POINT 6.17

◆ INTERPRETATION

The example business has a manager for the office but not for field staff: "partly".

2.3 D · Backup and continuity

D1 Daily automatic backup of all business data with one copy offline or otherwise out of an attacker's reach.

■ FACT

Every insurer form asks for it: how often, whether the media are physically separated from the active systems, whether change or destruction of the backup is excluded, whether the backup system sits in the same directory service, whether a backup and recovery concept exists (Mannheimer 4.1, 4.5, 4.6, 4.7, 4.9); Markel requires backups on separated systems or media at least weekly below one million euro turnover and daily above; Beazley's first critical requirement is tested offline backups; Funk's question 1 asks for a cold or offline location that would not be affected by a problem with the live environment. The Implementing Regulation requires backup copies "in a safe location or locations, which are not in the same network as the system, and are at sufficient distance to escape any damage from a disaster at the main site". ENISA's step 9 is "secure backups"; the Directive's area © names backup management and disaster recovery.

→ Source: Mannheimer, 4.1, 4.5, 4.6, 4.7, 4.9; Markel, section 4 point 5; Beazley, 1; Funk, 1; Implementing Regulation (EU) 2024/2690, Annex 4.2.2(c); ENISA, 12 steps, step 9; Directive (EU) 2022/2555, Art. 21(2)(c) · retrieved 2026-10-19

◆ INTERPRETATION

"Out of reach" is the whole point: a backup on a disk that is always connected, or in a cloud folder the office account can delete, is the next encrypted backup. Daily is the strictest rhythm in the forms and the one the toolkit asks. The example business backs up daily to a NAS in the office with no offline copy: "partly", first wave.

D2 Restore tested in the last twelve months, with the duration noted.

■ FACT

Mannheimer asks for the date of the last successful restore test of critical systems; Markel requires a restore test of all backups at least once a year; Beazley and Funk want backups tested regularly to make sure they can be restored. The Implementing Regulation requires regular testing of the recovery of backup copies and redundancies.

→ Source: Mannheimer, 4.2; Markel, 7.2; Beazley, 1; Funk, 1; Implementing Regulation (EU) 2024/2690, Annex 4.2.6 · retrieved 2026-10-19

◆ INTERPRETATION

Noting the duration is our addition; it turns the test into the answer to D3. One folder restored, time stopped, date and result on one line: that is the evidence. The example business has never tested: "not yet", first wave.

D3 How long the business could keep working without its IT.

■ FACT

Mannheimer asks for an emergency and recovery concept; the Implementing Regulation requires backup plans to state recovery times and a business continuity plan with the order of recovery; VdS 10000 has a chapter on identifying critical IT resources and one on recovery plans; TISAX carries assessment objectives for high availability.

→ Source: Mannheimer, 5.10; Implementing Regulation (EU) 2024/2690, Annex 4.1.2 and 4.2.2(a); VdS 10000:2025-01, chapters 9 and 17.5; ENX, NIS2 fulfilment through TISAX, table 1 · retrieved 2026-10-19

◆ INTERPRETATION

The question is not graded; it sets priorities. A business that can bridge a week with paper and phones needs a different plan from one that stops within hours. The answer goes into section D of the self-declaration and onto the emergency card ("we can bridge"). The example business: one day.

D4 A written emergency plan: whom to call, what to do first, in which order to restore.

FACT

The label's B14 asks whether the business has an emergency plan on the basis of which it reacts to an IT security incident, with the criterion that plans are tested at least every two years; Markel asks for an IT emergency plan that is fixed in writing and names responsible persons; Mannheimer for an emergency and recovery concept; ENISA's step 4 is "develop an incident response plan". The Implementing Regulation requires an incident handling policy with roles, responsibilities and procedures, and a business continuity plan with contact details, activation conditions and the order of recovery.

→ Source: Cyber Trust Austria, Schema Policy 2026, B14; Markel, 6.3; Mannheimer, 5.10; ENISA, 12 steps, step 4; Implementing Regulation (EU) 2024/2690, Annex 3.1.1 and 4.1.2 · retrieved 2026-10-19

INTERPRETATION

For a small business the emergency card is the plan: one page with the first hour, the numbers, the deadlines and where things are, modelled on the BSI's IT-Notfallkarte (section 4). Posting it and dating it is the evidence; a drill once a year, even at the desk, is the test the label wants. The example business has none: "not yet", first wave.

2.4 E · Updates and devices

E1 Updates installed automatically within days on every computer, phone and server.

FACT

The label's B9 asks whether all IT systems and applications are regularly updated with security updates, with the criterion that no security update may be overdue for longer than one quarter. Markel requires security patches within four weeks and critical ones with a CVSS score of 8.0 or higher without delay; Mannheimer asks for a patch management procedure for automatic or prompt installation; Allianz for a patch management that evaluates, prioritises and rolls out patches every working day; Beazley and Funk for critical patches as soon as possible. The Implementing Regulation requires that "security patches are applied within a reasonable time after they become available", tested before production, and from trusted sources. ENISA's step 6 begins with "keep software patched and up to date".

→ Source: Cyber Trust Austria, Schema Policy 2026, B9; Markel, 7.3; Mannheimer, 7.1; Allianz, 2.5.3; Beazley; Funk, 5; Implementing Regulation (EU) 2024/2690, Annex 6.6.1(a) to (c); ENISA, 12 steps, step 6 · retrieved 2026-10-19

INTERPRETATION

"Within days" is stricter than the label's quarter and Markel's four weeks; it is what automatic updates do on their own, and automatic is the only way a business without an IT department keeps up. A monthly check that they ran, noted on one line, is the evidence. The example business: "in place".

E2 A list of all devices, and every device and program still supported by its manufacturer.

FACT

The label's B4 asks for a regularly maintained directory of all IT assets and services including cloud services; Markel excludes access to outdated systems without manufacturer security updates, naming Windows 7, XP and NT, unless they sit on a separate network; Allianz asks whether no software beyond its end-of-life date is in use; Beazley and Funk exclude end-of-support and end-of-life software. The Implementing Regulation requires "a complete, accurate, up-to-date and consistent inventory" of assets; the Directive's area (i) names asset management.

→ Source: Cyber Trust Austria, Schema Policy 2026, B4; Markel, section 4 point 6; Allianz, 2.5.1; Beazley; Funk, 5; Implementing Regulation (EU) 2024/2690, Annex 12.4.1; Directive (EU) 2022/2555, Art. 21(2)(i) · retrieved 2026-10-19

INTERPRETATION

A device list of ten lines with a column "supported until" answers three questions at once: asset inventory, end of life, and who uses what. The example business has no written list and an old workshop computer: "partly", second wave; the computer leaves the network or gets replaced.

E3 Protective software on every computer; laptops and phones encrypted.

FACT

Mannheimer asks whether all systems have protection against malware with automatic updates; Markel for an endpoint protection solution that updates automatically and for anti-virus with current databases; Beazley and Funk for anti-virus or endpoint protection on all devices and the scanning of incoming email. The label's B11 asks whether systems are monitored for malware and B12 whether sensitive data is encrypted in transit. The Implementing Regulation requires protection "against malicious and unauthorised software" and a cryptography policy; ENISA's step 6 lists anti-virus, email and web protection and encryption; the Directive's area (h) names cryptography and encryption.

→ Source: Mannheimer, 7.2; Markel, section 4 point 5 and 7.3; Beazley; Funk, 6 and 7; Cyber Trust Austria, Schema Policy 2026, B11 and B12; Implementing Regulation (EU) 2024/2690, Annex 6.9.1 and 9; ENISA, 12 steps, step 6; Directive (EU) 2022/2555, Art. 21(2)(h) · retrieved 2026-10-19

INTERPRETATION

The built-in protection of current systems meets every form we read; nobody asks a small business for a product name. Device encryption of laptops and phones is our reading of ENISA's step 6 and the VdS chapter on mobile systems: a lost laptop without encryption is a reportable data breach, with encryption it is a lost laptop. The example business: "in place".

E4 For suppliers of software or devices: a contact for vulnerability reports and a support period for the products.

FACT

The Cyber Resilience Act obliges manufacturers of products with digital elements to handle vulnerabilities "for the support period", which "shall be at least five years" unless the product is expected to be in use for less; to designate "a single point of contact to enable users to communicate directly and rapidly with them, including in order to facilitate reporting on vulnerabilities", which "shall not limit such means to automated tools"; to put in place a policy on coordinated vulnerability disclosure; and to provide security updates without delay and free of charge. The Regulation applies from 11 December 2027; the duty to report actively exploited vulnerabilities applies from 11 September 2026. The Implementing Regulation asks relevant entities to track vulnerabilities and to write the handling of vulnerabilities into supplier contracts; the Directive's area (e) names "vulnerability handling and disclosure".

→ Source: Regulation (EU) 2024/2847 (Cyber Resilience Act), Art. 13(8) and (17), Art. 14, Art. 71, Annex I Part II points 2, 5, 6 and 8, Annex II point 2; Implementing Regulation (EU) 2024/2690, Annex 5.1.4(f) and 6.10; Directive (EU) 2022/2555, Art. 21(2)(e) · retrieved 2026-10-19

INTERPRETATION

A business that only uses software answers "not applicable" and loses nothing. A business that ships devices or software can publish a contact address and a support statement today, before the Regulation applies; both are what customers under the Implementing Regulation must ask for. The example business installs but does not manufacture: "not applicable".

E5 Router or firewall current, administrator password changed, remote administration off, a separate guest network.

FACT

Mannheimer asks whether the network was segmented; Markel requires firewalls at all transitions to the internet; the label's B7 asks for the manufacturer's recommended security settings and B10 whether the network is secured against unauthorised access from outside; VdS 10000 names segmentation and remote access in its network chapter; the Implementing Regulation requires configuration management, network security controls and segmentation; ENISA's step 7 is "secure your network" with firewalls and a review of remote access.

→ Source: Mannheimer, 7.4; Markel, section 4 point 5; Cyber Trust Austria, Schema Policy 2026, B7 and B10; VdS 10000:2025-01, chapter 11.5; Implementing Regulation (EU) 2024/2690, Annex 6.3, 6.7 and 6.8; ENISA, 12 steps, step 7 · retrieved 2026-10-19

INTERPRETATION

For a small business, segmentation means one thing: visitors and smart devices on a guest network that cannot see the office. The four items of the question are what an IT provider checks in an hour. The example business has a guest network but does not know the firmware state or the password: "partly", second wave.

2.5 F · Incidents and reporting

F1 Within what time you can report an incident to a customer who may be affected.

FACT

The Implementing Regulation expects supplier contracts to contain an obligation to report "without undue delay" incidents that present a risk to the security of the customer's systems. Covered entities themselves must send their authority an early warning "without undue delay and in any event within 24 hours of becoming aware", an incident notification within 72 hours and a final report within one month, and, where appropriate, notify the recipients of their services without undue delay of significant incidents that may affect the service. A DORA contract contains assistance in ICT incidents. The Austrian insurer's conditions require notice to the insurer at the latest within one week.

→ Source: Implementing Regulation (EU) 2024/2690, Annex 5.1.4(d); Directive (EU) 2022/2555, Art. 23(1) and (4); Regulation (EU) 2022/2554, Art. 30(2)(f); Donau Versicherung, AVB Cyber 2025, Teil D 7.1.4 · retrieved 2026-10-19

INTERPRETATION

The customer's own clock starts at 24 hours, so a clause will say "without undue delay" or name 24 hours. A small business can promise a phone call by the management within 24 hours of becoming aware; it cannot promise a written report with a root cause in that time, and D6 says so. The question lets you choose what you can hold; the emergency card shows it. The example business: 24 hours by phone through the management.

F2 Who checks after an incident whether personal data is affected, and who reports to the data protection authority within 72 hours.

FACT

A controller must notify a personal data breach to the supervisory authority "without undue delay and, where feasible, not later than 72 hours after having become aware of it", with reasons for any delay; a processor notifies the controller without undue delay; the notification describes the nature of the breach, the likely consequences and the measures taken. Where the breach is likely to result in a high risk, the data subjects are informed without undue delay, unless, among other exceptions, the data were encrypted. The Austrian authority offers an online form, a PDF form and an email address; the German authorities are those of the federal states.

→ Source: Regulation (EU) 2016/679, Art. 33(1) to (3), Art. 34(1) and (3)(a), English and German text; Datenschutzbehörde, Meldung Data Breach; BfDI, Landesbehörden · retrieved 2026-10-19

INTERPRETATION

The 72 hours are the hardest deadline a small business faces; they run from awareness, over weekends, and the first decision, whether personal data is affected, needs a named person. That person and the reporter stand on the emergency card. The example business knows the duty but has named nobody: "partly", first wave.

F3 Incidents in the last 24 months.

■ FACT

Insurance applications ask for past incidents, and the applicant's duty of disclosure is the legal reason: Mannheimer's form refers to § 19(5) of the German Insurance Contract Act. Two German courts dealt with cyber policies where the answers in the application did not match the facts.

→ Source: Mannheimer, section 15; LG Kiel, judgment of 23 May 2024, 5 O 128/21; OLG Schleswig, judgment of 8 January 2025, 16 U 63/24, both known from secondary sources only · retrieved 2026-10-19

◆ INTERPRETATION

The question has no basis in the three EU acts; it stands because every insurer asks and because a customer may. The honest answer is one of three: none, yes resolved and documented, unknown. "Unknown" is a legitimate answer for a business that has never kept a log; it becomes "none" or "yes" once the log exists (F4). The 24 months are the usual period of the forms, not a legal term. The example business: none.

F4 Incidents are written down: what happened, how, what was missing, what was changed.

■ FACT

The GDPR requires the controller to document breaches "comprising the facts relating to the personal data breach, its effects and the remedial action taken". The label's B13 asks for logging of system use so that incidents can be traced; the Implementing Regulation requires an incident handling policy covering documentation and reporting, logging, and post-incident reviews.

→ Source: Regulation (EU) 2016/679, Art. 33(5); Cyber Trust Austria, Schema Policy 2026, B13; Implementing Regulation (EU) 2024/2690, Annex 3.1.1, 3.2 and 3.6 · retrieved 2026-10-19

◆ INTERPRETATION

One page per incident, started even if empty, is the log. Technical logging of servers (the label wants ninety days) is the IT provider's part; the business's part is the page. The example business: "not yet", second wave.

2.6 G · People

G1 Briefing in the last twelve months on phishing, passwords and the reporting channel, with an attendance list.

FACT

Mannheimer asks whether staff are trained on IT security measures at least yearly; Markel for regular, at least annual awareness and training on information security, current threats and data protection; Beazley and Funk for annual training including anti-phishing for everyone with access to the network or to confidential data. The label's B2 asks whether staff are regularly trained; the Implementing Regulation requires that employees "including members of management bodies" are aware of the risks and apply cyber hygiene; the Directive's area (g) names cyber hygiene and training; ENISA's step 2 is "provide appropriate training".

→ Source: Mannheimer, 5.4; Markel, 6.4; Beazley, 4; Funk, 4; Cyber Trust Austria, Schema Policy 2026, B2; Implementing Regulation (EU) 2024/2690, Annex 8.1.1; Directive (EU) 2022/2555, Art. 21(2)(g); ENISA, 12 steps, step 2 · retrieved 2026-10-19

INTERPRETATION

Half an hour at the start of a team meeting, with the four topics and a list of who was there, is the training every form accepts; the list is the evidence, which is why the question asks for it. The example business has never held one: "not yet", second wave.

G2 Staff bound to confidentiality in writing.

FACT

The GDPR requires that persons authorised to process personal data for a processor "have committed themselves to confidentiality or are under an appropriate statutory obligation of confidentiality". The Implementing Regulation requires human resources security and that obligations which remain after the end of employment are laid down in the contract; the Austrian information security handbook has a chapter on personnel security.

→ Source: Regulation (EU) 2016/679, Art. 28(3)(b); Implementing Regulation (EU) 2024/2690, Annex 10.1 and 10.3.1; Österreichisches Informationssicherheitshandbuch, version 4.4.0, chapter 7 · retrieved 2026-10-19

INTERPRETATION

No questionnaire we read asks this in so many words; the question stands because the data processing agreement your customer signs with you promises it on your behalf. A clause in the employment contract or a signed addendum is enough. The example business: "in place".

G3 A payment rule: every change of bank details and every unusual payment request is confirmed by a call to a known number.

FACT

The Austrian criminal police office recommends against CEO fraud and business email compromise a four-eyes principle for payments, multi-level approval, the verification of bank detail changes exclusively through known contact channels and established callback procedures, and states that changes of bank details should never be carried out solely on the basis of an email. The chamber of commerce of Upper Austria warns of invoices with swapped IBANs and advises to query any change not only by email but also by telephone, before the transfer, on a number already known, with a second person checking payment orders. ENISA's SME report describes the compromised mailbox as the entry to this fraud.

→ Source: Bundeskriminalamt, CEO Fraud / Business E-Mail Compromise, updated 29 June 2026; Wirtschaftskammer Oberösterreich, Betrug mit geänderten Kontodaten, 22 July 2025; ENISA, Cybersecurity for SMEs, June 2021 · retrieved 2026-10-19

INTERPRETATION

This is the one question that no security questionnaire asks and that costs small businesses the most money. It is priority 1 because it needs no technology: a rule, a known number, two people. The example business: "in place".

2.7 H · Your own providers and the cloud

H1 A list of the providers that process your data or your customers' data, with country and purpose.

FACT

The Implementing Regulation requires "a directory of their direct suppliers and service providers" with contact points and the list of products and services each provides; the label's A11 asks for a process to manage supplier risks; ENISA's step 3 is "ensure effective third party management"; the Directive's area (d) names direct suppliers and service providers. The GDPR's record of processing activities is not required of businesses with fewer than 250 staff unless the processing is not occasional, which for email and file storage it is not.

→ Source: Implementing Regulation (EU) 2024/2690, Annex 5.2; Cyber Trust Austria, Schema Policy 2026, A11; ENISA, 12 steps, step 3; Directive (EU) 2022/2555, Art. 21(2)(d); Regulation (EU) 2016/679, Art. 30(1) and (5) · retrieved 2026-10-19

INTERPRETATION

Five to ten lines: email, file storage, accounting, website, the IT provider; with country, purpose, contract and contact. The list answers the customer's subcontracting question (D6) before it is asked. The example business has a list in its head: "partly".

H2 Data processing agreements with these providers, and their security settings switched on.

FACT

A controller uses only processors that provide sufficient guarantees, and the processing is governed by a contract with the contents of Article 28(3). Beazley and Funk ask for MFA for cloud-based services; the Implementing Regulation asks relevant entities to write cybersecurity requirements into supplier contracts and to apply security in the acquisition of ICT services; ENISA's step 10 is "engage with the cloud".

→ Source: Regulation (EU) 2016/679, Art. 28(1) and (3); Beazley, 2; Funk, 2; Implementing Regulation (EU) 2024/2690, Annex 5.1.4(a) and 6.1; ENISA, 12 steps, step 10 · retrieved 2026-10-19

INTERPRETATION

The large providers offer the agreement as a click in the admin console; the evidence is the downloaded copy. "A second administrator" is our addition: a cloud tenant with one administrator who leaves, forgets the password or loses the phone is a locked business. The example business: agreements yes, console settings unchecked: "partly".

H3 The customer is informed before a provider that processes their data is changed.

FACT

The Implementing Regulation expects supplier contracts to regulate subcontracting and the requirements for subcontractors; a DORA contract names the locations of processing and requires prior notice of their change; under the GDPR a processor engages another processor only with the controller's prior authorisation and, under a general authorisation, informs the controller of any intended change so that it can object.

→ Source: Implementing Regulation (EU) 2024/2690, Annex 5.1.4(g); Regulation (EU) 2022/2554, Art. 30(2)(a) and (b); Regulation (EU) 2016/679, Art. 28(2) · retrieved 2026-10-19

INTERPRETATION

The rule costs one template email. The example business has none: "not yet", third wave.

2.8 I · Evidence, dates and review

I1 At the end of a contract, the customer's data is returned or deleted, and you can confirm it in writing.

FACT

The Implementing Regulation names obligations upon termination of the contract, "such as retrieval and disposal" of the information; DORA names access, recovery and return of data; the GDPR processor contract says the processor "deletes or returns all the personal data to the controller after the end of the provision of services".

→ Source: Implementing Regulation (EU) 2024/2690, Annex 5.1.4(h); Regulation (EU) 2022/2554, Art. 30(2)(d); Regulation (EU) 2016/679, Art. 28(3)(g) · retrieved 2026-10-19

◆ INTERPRETATION

A one-paragraph rule and a confirmation template answer the clause. The example business: "in place".

I2 to I4 Date of the self-declaration, first wave, review. The date on D1 and D7 (I2), the target date of the first wave (I3; the second and third waves follow at plus two and plus five months), and the review rhythm of six or twelve months (I4).

■ FACT

The Austrian label is valid for one year; VdS certificates are re-audited yearly; Mannheimer asks whether the business runs regular analyses; the Implementing Regulation requires regular compliance monitoring and reporting to the management.

→ Source: Cyber Trust Austria, Schema Policy 2026, section 4.6; VdS 5569, p. 9; Mannheimer, 5.3; Implementing Regulation (EU) 2024/2690, Annex 2.2.1 · retrieved 2026-10-19

◆ INTERPRETATION

Twelve months is the rhythm of every scheme we read; six for a business that is working through many open points. The review date stands on D7 and on the review sheet of D2 with four triggers: a new customer questionnaire, a departure, a new provider, an incident.

3 Evidence

What a questionnaire accepts. Nobody audits a ten-person supplier; the reviewer wants a dated document per answer that could be shown if someone asked. The evidence list (D4) names one per question, gives it an attachment number if it exists, and a date and a sentence on how it arises if not. The attachments live in the folder named in question A8; D1 and D5 refer to the numbers.

How each piece of evidence arises in an hour or less. The account list with daily and administrator accounts (C1, C4, C5): one table, written from the systems you have. Screenshots of the MFA settings or the administrator report (C2, C3, H2): one per system. The written rules (B1, C6, G3, H3, I1): two pages, signed. The backup settings and the location of the copy out of reach (D1): one screenshot and one sentence. The restore test record (D2): one line with date, duration and result. The emergency card (D4, F2): printed, dated, posted. The update check (E1): one line per month. The device list (E2, E3): one table with "supported until" and an encryption column. The router check (E5): date and settings. The incident log (F4): one page, started. The attendance list (G1): date, topics, names. The confidentiality clause (G2): the contract page or the addendum. The provider list (H1): one table. The agreements (H2): the downloaded copies. A policy or a certificate (B2, B3): the document itself.

◆ INTERPRETATION

Thirteen of these come from the old supplier response kit and have been accepted in practice by customers and insurers; none requires a tool you do not already have. What you cannot show on the day goes into D4 with the date from the action plan, and the cover letter says so. That is what distinguishes a self-declaration from a questionnaire answered with "yes" throughout.

Attachment numbers and the folder. D4 numbers only what exists; a gap keeps its question number and its date. The folder in A8 holds the attachments, the self-declaration, the plan, the card and the evidence summary, and its path stands on the emergency card so that the deputy finds it. Keep the folder outside the systems that could be encrypted, or keep a copy there.

The review. On the date in D7 the business opens the generator, changes what has changed, and freezes a new version; the account keeps every frozen version with its date and shows which predate an update of the toolkit. The review sheet of D2 names the four triggers that bring the date forward.

4 The emergency

4.1 The first hour

■ FACT

The Austrian government's security portal advises that an infected computer should be cut off from power immediately, that experts advise against paying the ransom, and that the incident should be reported at the nearest police station. The German BSI's twelve questions for the first response ask whether affected systems and the internet connection were disconnected, whether backups were stopped and protected from further effects, whether logs, notes and photos of screens were secured, whether police or authorities were informed after coordination, and whether access rights were checked. The BSI's IT-Notfallkarte, modelled on the fire notice, carries three messages: know the contact and how to reach them, pass on the decisive information at once, take countermeasures only after consultation.

→ Source: onlinesicherheit.gv.at, Erpressungstrojaner, last updated 23 July 2022; BSI and partners, TOP 12 Maßnahmen bei Cyber-Angriffen, September 2019; BSI and Allianz für Cyber-Sicherheit, IT-Notfallkarte · retrieved 2026-10-19

◆ INTERPRETATION

The card combines them into four steps: disconnect, do not delete and do not plug in the backup, call, write down. On the question whether to switch off, the sources differ: the Austrian portal says cut the power, the BSI's list wants traces secured. The card says: do not switch off if help arrives shortly, because traces are lost; switch off if nobody comes and the encryption spreads visibly. No ransom without talking to the police and the insurer first; payment guarantees nothing. Everything on the card must be on paper, because the computer may be the thing that is encrypted.

4.2 Deadlines

Personal data: 72 hours. Section 2.5, F2. The clock starts when the business becomes aware; the named person decides within the first day whether personal data is affected; the report goes to the authority of the country (section 5); the data subjects are informed if the risk is high.

Customers under NIS 2. Section 2.5, F1. Your customer's early warning is due within 24 hours of its own awareness; your call is what starts its clock. If your business is itself covered by NIS 2 (the free NIS2 memo on scutoria.com says in five questions whether it is), the same deadlines apply to you towards your authority.

Insurer, bank, police. The policy names its deadline; the Austrian conditions we read say one week. After a fraudulent transfer, the criminal police office says: contact your bank immediately, request a recall, preserve the emails and screenshots, report at the police station.

→ Source: Donau Versicherung, AVB Cyber 2025, Teil D 7.1.4; Bundeskriminalamt, CEO Fraud, updated 29 June 2026 · retrieved 2026-10-19

4.3 Afterwards

■ FACT

The GDPR requires the breach to be documented with its facts, effects and remedial action; the Implementing Regulation requires post-incident reviews. The BSI list ends with checking access rights: new passwords, second factor.

→ Source: Regulation (EU) 2016/679, Art. 33(5); Implementing Regulation (EU) 2024/2690, Annex 3.6; BSI, TOP 12 · retrieved 2026-10-19

◆ INTERPRETATION

From a clean device: change the passwords of email, bank and cloud, check the second factor, write the one page for the incident log (F4). The page is also what the insurer and the customer will ask for, and it is what makes the next self-declaration true.

5 Country notes

The Union rules in sections 1, 2 and 4 apply in every member state. What differs is the authority, the hotline, the police contact and the national label or check. The emergency card picks the contacts from question A2.

5.1 Austria

FACT

The NISG 2026 is in force in its core provisions since 1 October 2026; the cybersecurity authority is the Bundesamt für Cybersicherheit; covered entities register by 1 January 2027, send a self-declaration within twelve months of the registration duty and face an audit request at the earliest two years after the law's entry into force; the NISV 2026 of 1 October 2026 makes the Annex of the Implementing Regulation the catalogue for all of them. The Cyber-Security-Hotline of the chambers of commerce answers at 0800 888 133 around the clock, free for members, with a free first consultation by an IT security firm. CERT.at takes reports at

reports@cert.at

and +43 1 5056416 78. The police emergency number is 133, the European 112; the criminal police office takes tips at

against-cybercrime@bmi.gv.at

but no formal complaint, which is filed at a police station. The data protection authority takes breach notifications by online form, PDF form or email to

dsb@dsb.gv.at

, immediately and if possible within 72 hours. The Austrian information security handbook, version 4.4.0 of 6 November 2023 by the Federal Chancellery and A-SIT, is free and follows ISO 27001 in eighteen chapters.

→ Source: NISG 2026, §§ 29, 32, 33; NISV 2026, § 2; Bundesamt für Cybersicherheit; WKO, Cyber-Security-Hotline, 1 June 2026; CERT.at; polizei.gv.at, Notrufnummern; Bundeskriminalamt, Meldestellen; Datenschutzbehörde, Meldung Data Breach; sicherheitshandbuch.gv.at · retrieved 2026-10-19

INTERPRETATION

For an Austrian supplier, the label (section 1.5) is the natural second step if a customer wants more than the self-declaration; its fourteen Standard questions overlap with blocks B to H of this toolkit, so the answers here are the answers there.

5.2 Germany

FACT

The amended BSI Act is in force since 6 December 2025; covered entities had to register with the BSI within three months, and the BSI offers a self-check of coverage. The BSI publishes the CyberRisikoCheck for small businesses, the IT-Notfallkarte and, with the Allianz für Cyber-Sicherheit, the TOP 12 measures; the police of each federal state runs a Zentrale Ansprechstelle Cybercrime for businesses, listed at polizei.de; the police emergency number is 110; the data protection authorities for private businesses are those of the federal states, listed by the federal commissioner. VdS 10000 is the SME standard insurers name.

→ Source: BSI-Gesetz, in force 6 December 2025; BSI, NIS-2 pages, CyberRisikoCheck, IT-Notfallkarte; polizei.de, ZAC; BfDI, Landesbehörden; VdS · retrieved 2026-10-19

◆ INTERPRETATION

A German supplier outside the digital sectors is not bound by the Implementing Regulation, but its customers' auditors read it; the eight contract contents of D6 are therefore equally useful. The CyberRisikoCheck is the cheapest external check and asks, in its six areas, what blocks B to H ask.

5.3 Other member states

◌ GAP

The toolkit did not survey the authorities, hotlines or labels of other member states. What applies everywhere: the Directive as transposed, the Implementing Regulation for digital providers, DORA for financial customers, the GDPR's 72 hours, the Cyber Resilience Act. The emergency card for another EU country names the European emergency number 112, the national computer emergency team (ENISA keeps a list) and the national data protection authority, and leaves the hotline open. A business elsewhere fills the three fields from its own chamber or authority.

6 Open points

The old supplier response kit of September 2026 listed sixteen uncertainties. Each was checked again at the originals on 19 October 2026; the table says what changed. Seven new points were added.

No.	Question	Status on 19 October 2026
6.1	Was the wording of the Directive, DORA and the Implementing Regulation read at the Official Journal?	Resolved. All three read at EUR-Lex in English, the Directive and the Implementing Regulation also in German; the quotes in sections 1 and 2 are from the originals.
6.2	Were §§ 32 and 33 NISG 2026 read?	Resolved. Read in the Federal Law Gazette of 23 December 2025; section 1.1 cites them.
6.3	When does the twelve-month period for the Austrian self-declaration start?	Partly. § 33(1) says after the registration duty arises; the first audit request comes at the earliest two years after entry into force. The old forecast that questionnaires fall into 2027 remains a market expectation.
6.4	Has the Austrian authority extended the Implementing Regulation to other sectors?	Resolved. Yes: NISV 2026, § 2, of 1 October 2026. The eight contract contents are the pattern for every Austrian NIS 2 customer.
6.5	Was the Cyber Resilience Act read in the original?	Resolved. English Official Journal text read; the support period of at least five years and the single point of contact are quoted in section 2.4. German wording not read.
6.6	Is there an official model supplier questionnaire?	Open. None found; the questions follow the sources named per question, and six insurer forms were read verbatim.

No.	Question	Status on 19 October 2026
6.7	Which questions have no public source?	Narrowed. Cyber insurance (B2) remains without legal basis and is marked so; past incidents (F3) rest on the duty of disclosure and insurer practice; confidentiality (G2) now rests on Art. 28(3)(b) GDPR; the payment rule (G3) on the criminal police office and the chamber.
6.8	Are the six areas of DIN SPEC 27076 taken from the specification?	Partly. They come from the BVMW guide of August 2023 co-written by BSI staff; the specification itself is behind a free registration and was not read.
6.9	Is the GDV model questionnaire known in full?	Replaced. Six public insurer forms were read in full instead; the GDV model was not pursued.
6.10	Is anything claimed from ISO/IEC 27001 beyond its structure?	No. The handbook states the 93 controls in four themes from the committee's own journal and claims no content of the paid standard.
6.11	Criteria, cost and duration of labels and certificates?	Resolved for the Austrian label: questions and prices read at the scheme policy and the website; whether a named customer demands it was not found. ISO certification cost for small businesses not surveyed.
6.12	ENISA survey figures?	Dropped. The handbook no longer cites them.
6.13	Number of fields of the self-declaration?	Closed. The toolkit asks forty questions, 24 of them status questions.
6.14	Delegated Regulation (EU) 2025/532, Implementing Regulation (EU) 2024/2956, the German financial supervisor's contract contents, the GDV DORA model clauses, the Austrian financial market authority's pages?	Open. Known by title only; Part B of D6 rests on DORA Article 30 itself. That customers of other sectors copy the eight contents of the Implementing Regulation remains an assessment, now supported for Austria by the NISV 2026.
6.15	Is a data processing agreement needed in the individual case?	Open by design. A legal question of the individual case that the toolkit does not answer; H2 asks whether the agreements exist where personal data is processed.
6.16	Does the wording match the companion handbook of the old kit?	Resolved. That handbook was never delivered; this handbook is now the primary text and refers to no other.
6.17	New: periodic password change.	The Implementing Regulation requires changes at predefined intervals; NIST and the BSI advise against. Section 2.2, box.
6.18	New: the legal references of the Austrian label.	Its scheme policy cites § 11 NISV and § 17(3) NISG of the former law; its website cites § 33 NISG 2026. Not clarified with the issuer.
6.19	New: the current version of the VDA ISA catalogue.	vda.de names version 7 and ISA 2027.1; enx.com lists ISA 6.0.3 as current. Not resolved.
6.20	New: VdS 10000 list price and full text.	Only a six-page extract with the table of contents was obtained.
6.21	New: the wording of §§ 3 to 5 NISV 2026.	Read as a summary of the retrieval, not verbatim; section 1.6 paraphrases § 4.

No.	Question	Status on 19 October 2026
6.22	New: whether a court has ruled on the password conflict or on "without undue delay" for small suppliers.	Not searched.
6.23	New: the German court decisions on cyber insurance applications.	Known from secondary sources only; cited as such in section 2.5.

7 Glossary

Asset inventory. The list of all devices, systems and services, with who uses what and until when it is supported; question E2 and point 12.4.1 of the Implementing Regulation.

Recovery time. How long the business can bridge without its IT (question D3) and how long a restore takes (D2). Questionnaires call it RTO.

Multi-factor authentication (MFA). Sign-in with a second factor next to the password: an app, a security key, or as a last resort a code by SMS. Questions C2 and C3.

Phishing-resistant. An authenticator that cannot be tricked by a fake page: a security key or a passkey, as ranked by NIST and CISA.

Privileged account. An account with administrator rights; kept separate from the daily account (C5).

Segmentation. Splitting a network so that visitors and devices that need no access cannot reach the office systems; the guest network of question E5.

Backup out of reach. A copy an attacker with the office's rights cannot delete or encrypt: offline, rotated, or immutable (D1).

Restore test. Restoring real data from the backup and noting date, duration and result (D2).

Data processing agreement. The contract under Art. 28(3) GDPR between a controller and a processor (H2).

Subcontractor. A provider your provider uses, or a provider you use for the customer's data; customers want to know of changes (H3).

Audit right. The clause under which a customer may inspect or receive reports; point 5.1.4(e) of the Implementing Regulation and Art. 30(3)(e) DORA; D6 says what a small business can accept.

Essential and important entity. The two classes of businesses covered by NIS 2; the customers that send questionnaires.

Relevant entities. The digital providers the Implementing Regulation binds directly; in Austria, by the NISV 2026, every NIS 2 entity.

Self-declaration. D1 of this toolkit; also the Austrian label's Standard level and the filing under § 33 NISG 2026, which are different documents.

Significant incident. Under the Implementing Regulation an incident with a loss above 500 000 euro or five percent of turnover, among other criteria; the threshold at which your customer's own deadlines start.

Support period. The time for which a manufacturer handles vulnerabilities of a product under the Cyber Resilience Act; at least five years (E4).

Single point of contact. The manufacturer's contact for vulnerability reports, not limited to automated tools (E4).

Coordinated vulnerability disclosure. The policy under which a manufacturer receives and fixes reported vulnerabilities before they are published.

Attachment number. The number D4 gives each piece of evidence that exists; D1 and D5 refer to it.

Frozen version. A dated copy of the document set kept in the account; the review creates a new one.

Gap. In this toolkit: a field the business fills itself, with a sentence next to it that says what the decision means and where the handbook explains it.

8 Sources

All sources were read at the originals on 19 October 2026, except where the entry says otherwise. EUR-Lex and RIS texts were opened in a browser and the article text was copied from the page; PDF documents were downloaded and searched by page; the questionnaire catalogues and insurer forms were collected by web search and retrieval and spot-checked. Copies of the PDFs are kept with the project. Quotations from German sources are our translations.

Union law

1. Directive (EU) 2022/2555 of the European Parliament and of the Council of 14 December 2022 (NIS 2 Directive). Art. 2(1) and (2), Art. 3, Art. 21(1) to (5), Art. 23(1) and (4), Annexes I and II; English and German. eur-lex.europa.eu/legal-content/EN/TXT/HTML/?uri=CELEX:32022L2555 · retrieved 2026-10-19.

2. Commission Implementing Regulation (EU) 2024/2690 of 17 October 2024 laying down rules for the application of Directive (EU) 2022/2555 as regards technical and methodological requirements of cybersecurity risk-management measures, OJ L, 2024/2690, 18.10.2024, in force since 7 November 2024. Art. 2, 3(1), 16; recitals 3 and 5; Annex 1 to 13, in particular 1.1, 2.2, 2.3, 3.1, 3.2, 3.6, 4.1, 4.2, 5.1.4, 5.2, 6.1, 6.3, 6.6, 6.7, 6.8, 6.9, 6.10, 7, 8.1, 9, 10.1, 10.3, 11.2, 11.3, 11.5, 11.6, 11.7, 12.4, 12.5; English and German. eur-lex.europa.eu/legal-content/DE/TXT/HTML/?uri=OJ:L_202402690; Commission text C(2024) 7151 final · retrieved 2026-10-19.
3. Regulation (EU) 2022/2554 of the European Parliament and of the Council of 14 December 2022 on digital operational resilience for the financial sector (DORA). Art. 28(8), Art. 30(1) to (5); English. eur-lex.europa.eu, CELEX 32022R2554 · retrieved 2026-10-19.
4. Regulation (EU) 2016/679 (General Data Protection Regulation), consolidated version of 4 May 2016. Art. 28(1) to (3), Art. 30(1) and (5), Art. 32(1), Art. 33, Art. 34; English and German. eur-lex.europa.eu, CELEX 02016R0679-20160504 · retrieved 2026-10-19.
5. Regulation (EU) 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements (Cyber Resilience Act), OJ L, 2024/2847, 20.11.2024. Art. 2(1), 3(1), 13(1), (8), (17), 14(1) and (2), 71; recitals 63 and 64; Annex I Part II; Annex II; English. eur-lex.europa.eu/legal-content/EN/TXT/HTML/?uri=OJ:L_202402847 · retrieved 2026-10-19.
6. Commission Recommendation 2003/361/EC of 6 May 2003 concerning the definition of micro, small and medium-sized enterprises, Annex, Art. 2 · retrieved 2026-10-19.

Austria

7. Netz- und Informationssystemsicherheitsgesetz 2026 (NISG 2026), BGBl. I No. 94/2025 of 23 December 2025, in force in its core provisions since 1 October 2026. §§ 3a, 24, 25, 26, 29, 32, 33, 51. ris.bka.gv.at, Federal Law Gazette PDF · retrieved 2026-10-19.
8. Netz- und Informationssystemsicherheits-Verordnung 2026 (NISV 2026), regulation of the Cybersicherheitsbehörde, BGBl. II No. 290/2026 of 1 October 2026. §§ 1, 2, 9 verbatim; §§ 3 to 5 as summarised by the retrieval. ris.bka.gv.at · retrieved 2026-10-19.
9. Bundesamt für Cybersicherheit, pages on registration and duties · retrieved 2026-10-19.
10. Wirtschaftskammern Österreichs, Cyber-Security-Hotline, page dated 1 June 2026. wko.at/it-sicherheit/cyber-security-hotline · retrieved 2026-10-19.
11. CERT.at, home page and contact. cert.at · retrieved 2026-10-19.
12. Bundeskriminalamt, Meldestellen (bundeskriminalamt.at/602) and CEO Fraud / Business E-Mail Compromise (bundeskriminalamt.at/212/eigentum/betrug/ceo_fraud.html), last updated 29 June 2026 · retrieved 2026-10-19.

13. polizei.gv.at, Notruf- und Notfallnummern in Österreich · retrieved 2026-10-19.
14. Datenschutzbehörde, Meldung Data Breach. dsb.gv.at · retrieved 2026-10-19.
15. onlinesicherheit.gv.at (Bundeskanzleramt and A-SIT), Erpressungstrojaner: Was tun bei Infektion?, last updated 23 July 2022 · retrieved 2026-10-19.
16. Wirtschaftskammer Oberösterreich, Achtung: Betrug mit geänderten Kontodaten in E-Mails und PDF-Rechnungen, 22 July 2025 · retrieved 2026-10-19.
17. Cyber Trust Austria (CTS Cyber Trust Services GmbH, KSV1870, Kompetenzzentrum Sicheres Österreich), Cyber Risk Rating & Cyber Trust Label Schema Policy 2026, version 6.0 of 8 September 2025, 23 pages; cyber-trust.at, label overview, B questions, FAQ · retrieved 2026-10-19.
18. Bundeskanzleramt and A-SIT, Österreichisches Informationssicherheitshandbuch, version 4.4.0 of 6 November 2023. sicherheitshandbuch.gv.at · retrieved 2026-10-19.

Germany

19. Gesetz über das Bundesamt für Sicherheit in der Informationstechnik (BSI-Gesetz) as amended by the German NIS 2 transposition act, in force since 6 December 2025. §§ 28, 30, 32, 33. gesetze-im-internet.de · retrieved 2026-10-19.
20. Bundesamt für Sicherheit in der Informationstechnik: NIS-2 für IT und TK; CyberRisikoCheck (bsi.bund.de/dok/crc); press release of 6 June 2025; Die Lage der IT-Sicherheit in Deutschland, section on SMEs; IT-Notfallkarte (bsi.bund.de/dok/13003500, allianz-fuer-cybersicherheit.de); press releases on passwords of 31 January 2025 and 30 January 2026; IT-Grundschutz-Kompendium, edition 2023, ORP.2 and ORP.4 · retrieved 2026-10-19.
21. BSI, Bundeskriminalamt, Charter of Trust, DIHK, eco, Initiative Wirtschaftsschutz, NIFIS, VOICE, Allianz für Cyber-Sicherheit, TOP 12 Maßnahmen bei Cyber-Angriffen, September 2019 · retrieved 2026-10-19.
22. BVMW with BSI, Die Anwendung des CyberRisiko-Checks auf Basis der DIN SPEC 27076, Leitfaden für IT-Dienstleistungsunternehmen, August 2023; DIN Media, DIN SPEC 27076:2023-05, product page · retrieved 2026-10-19. The specification itself was not read.
23. Polizei, Zentrale Ansprechstellen Cybercrime (polizei.de); BfDI, Kontakt zu den Landesbehörden · retrieved 2026-10-19.
24. VdS Schadenverhütung GmbH, VdS 10000 : 2025-01 (03), Informationssicherheitsmanagementsystem für kleine und mittlere Unternehmen, extract with table of contents; VdS 5569 : 2018-10, Cyber-Security-Standards für den Mittelstand; vds.de · retrieved 2026-10-19.

EU agencies and standards bodies

25. ENISA, Cybersecurity guide for SMEs: 12 steps to securing your business, 28 June 2021; Cybersecurity for SMEs: Challenges and Recommendations, June 2021 · retrieved 2026-10-19.
26. ENISA, NIS2 Technical Implementation Guidance, version 1.0, June 2025, 170 pages · retrieved 2026-10-19. Advisory, not binding.
27. NIST, Special Publication 800-63B-4, Digital Identity Guidelines: Authentication and Authenticator Management, July 2025, sections 3.1.1.1, 3.1.1.2, 3.2.2 · retrieved 2026-10-19.
28. CISA, Implementing Phishing-Resistant MFA, October 2022 · retrieved 2026-10-19.
29. ISO/IEC 27001:2022, bibliographic data at committee.iso.org and the IEC Webstore; SC 27 Journal 2025, issue 1 · retrieved 2026-10-19. The standard itself was not read.
30. ENX Association, TISAX handbook, version 2.8; NIS2 fulfilment through TISAX, 24 April 2025; VDA, information security pages · retrieved 2026-10-19.
31. Shared Assessments, SIG, and Which SIG Should I Use?, 2023 · retrieved 2026-10-19.

Insurers

32. Mannheimer Versicherung AG, Fragebogen Cyber-Risiken für Unternehmen ab 10 Mio. Euro Umsatz, HF_060 0424 · retrieved 2026-10-19.
33. Markel Insurance SE, Fragebogen für Cyber-Versicherungen Pro Cyber v2 · retrieved 2026-10-19.
34. Allianz Versicherungs-AG, Fragebogen für Unternehmen der Informationstechnologie, 9.25 · retrieved 2026-10-19.
35. Beazley, Sicherheitsanforderungen für die Cyber Versicherung, undated, hosted by WKO · retrieved 2026-10-19.
36. Funk International Austria GmbH with Beazley, Versicherungsantrag und Risikofragebogen Cyber-Versicherung, July 2022 · retrieved 2026-10-19. Broker form.
37. Donau Versicherung AG, Allgemeine Bedingungen für die Cyberversicherung (Fassung 2025), 4 August 2025 · retrieved 2026-10-19.
38. LG Kiel, judgment of 23 May 2024, 5 O 128/21; OLG Schleswig, judgment of 8 January 2025, 16 U 63/24; known from secondary sources, not read.